

A 68-year-old woman from Andheri West in Mumbai has fallen victim to a sophisticated “digital arrest” scam, in which fraudsters allegedly posed as police officers, CBI officials and even a judge to extract nearly all her life savings, according to a report by Bar and Bench.

According to police, the woman was coerced into transferring ₹3.71 crore after being made to believe she was under investigation in a money-laundering case. The West Region Cyber Police Station has registered an FIR against unidentified persons and launched a probe into the elaborate fraud.

As per the complaint, the ordeal began in August 2025 when the woman received a call from a man claiming to be “Vijay Paul”, who said he was connecting her to Colaba Police Station. She was later contacted via WhatsApp video calls by individuals impersonating police and CBI officials, who alleged that her Aadhaar details had been misused to open a bank account linked to illegal transactions.

The fraudsters reportedly warned her of imminent arrest and instructed her not to share details with anyone. She was told she was under constant surveillance and that her case would soon be heard in court.

During a staged video call, a man dressed in judicial robes was introduced as “Judge Chandrachud” and conducted a fake hearing. She was allegedly told her bail had been denied and that she must transfer her assets to “secure” accounts for verification to prove her innocence.

Fearing arrest, the woman transferred funds over several weeks. She approached cyber police after realising the money was not being returned and further demands were made. Investigators are now tracking the accounts used in the scam.

Mumbai: A 65-year-old man recently lost Rs 5.20 lakh in a digital arrest fraud. The complainant is a resident of Mira Road and works in the merchant navy.

Recently, he received a video call from a person wearing a police uniform. The caller claimed to be an officer from Juhu police station and informed the complainant that his name had come up in a money laundering case.

Despite denying claims, the scammer then told the complainant to ‘cooperate in the investigation’ and transfer money to a ‘Reserve Bank’ account till the money laundering probe is over. Bogus documents were shared with regards to the money laundering case with the complainant over WhatsApp.

The frightened complainant then transferred Rs 5.20 lakh in different beneficiary bank accounts. He was asked to pay more, which made him realise that he had been scammed. A case was registered with the MBVV police.

Awareness and vigilance form the foundation of effective cybersecurity by equipping individuals with the knowledge to identify and respond to potential threats. When

employees are aware of risks such as phishing, ransomware, and social engineering, they can avoid falling victim to common cyber scams. Vigilance ensures that individuals and teams consistently monitor for unusual activities, such as unauthorized access attempts or suspicious emails, which can signal a cyberattack. Early detection enabled by vigilance allows swift action to contain threats, minimizing damage. Additionally, fostering a culture of awareness helps in creating proactive habits, such as regularly updating passwords and verifying sources before sharing sensitive information. Together, awareness and vigilance significantly reduce vulnerabilities and strengthen overall cybersecurity defences

### **Cybersecurity is Shared Responsibility**

The primary objective of this segment is to instil a strong understanding among employees that cybersecurity is a collective responsibility. While IT teams provide the tools, protocols, and infrastructure to safeguard the organization, employees act as the first line of defence. Cyber threats often exploit human errors, making every employee's vigilance and proactive behaviour crucial for organizational security.

### **1.Cybersecurity Is Everyone's Responsibility**

**Demystify the IT Myth** Many employees mistakenly believe cybersecurity is solely the IT department's duty. Highlight that IT teams manage the infrastructure, but it's the employees who interact with systems, data, and external entities daily.

Many employees mistakenly believe that cybersecurity is solely the responsibility of the IT department, which leads to a dangerous misconception often referred to as the "IT myth." While IT teams play a critical role in managing the organization's technological infrastructure, securing networks, and implementing protective measures, they are not the only ones responsible for safeguarding the organization against cyber threats. Employees are the ones who interact with systems, access sensitive data, communicate with external entities, and make daily decisions that can either strengthen or weaken the organization's defenses. Without active participation and vigilance from everyone, even the most sophisticated IT systems can be rendered vulnerable

**The Human Factor:** Over 90% of cyberattacks are linked to human error (e.g., clicking on phishing links or using weak passwords). Employees are often the weakest link in the cybersecurity chain.

The human factor is one of the most significant vulnerabilities in cybersecurity. Research consistently shows that over 90% of cyberattacks involve some form of human error, such as

clicking on phishing emails, downloading malicious attachments, or reusing weak passwords across multiple platforms. These seemingly minor mistakes can have devastating consequences, from data breaches to financial losses and reputational damage. Attackers frequently target employees because they recognize that human behavior is often the weakest link in the security chain. Understanding this vulnerability underscores the importance of employee education and awareness in minimizing risks.

**Team Effort:** Cybersecurity success relies on collaboration between IT teams and employees. Employees must adhere to guidelines, report anomalies, and practice safe behaviors.

Effective cybersecurity is ultimately a team effort that requires close collaboration between IT teams and employees. IT departments provide the tools, protocols, and support necessary for maintaining a secure environment, but employees must adhere to these guidelines, remain vigilant, and take proactive steps to identify and report potential threats. This partnership relies on open communication, mutual accountability, and a shared commitment to security. By fostering a culture where cybersecurity is everyone's responsibility, organizations can create a stronger and more resilient defense against the growing range of cyber threats

## **2. Individual Actions Matter**

**Every Click Counts:** A single click on a malicious link or attachment can compromise the entire organization. Individual actions play a pivotal role in ensuring cybersecurity within an organization, as even seemingly minor decisions can have significant consequences. Every click matters in today's interconnected digital environment. For example, a single click on a malicious

link or downloading a compromised attachment can open the gateway for cybercriminals to infiltrate an organization's network, steal sensitive data, or disrupt operations. This is particularly concerning because employees routinely handle confidential and sensitive information, such as client records, proprietary data, and financial transactions. As a result, attackers often target employees, knowing that human behaviour can be easier to exploit than technological defences. Practicing secure habits not only safeguards the organization's assets but also protects employees' personal information from being exposed or misused. Employees handle sensitive data daily, making them prime targets for attackers. Practicing secure habits protects not just the organization but also personal information.

## **3. Key Responsibilities of Employees:**

Employees have several key responsibilities in maintaining cybersecurity. First and foremost, they must develop the ability to identify and avoid phishing attempts and social engineering tactics. Phishing e-mails, for instance, often appear to be from trusted sources but are designed to trick recipients into revealing sensitive information or clicking on harmful links. Similarly,

social engineering exploits human psychology to manipulate employees into breaching security protocols. Recognizing these threats requires vigilance and continuous education.

Another critical responsibility is safeguarding login credentials. Employees must ensure that passwords are strong, unique, and not shared with others. Using tools like password managers can help maintain this standard. Additionally, employees should never reuse passwords across personal and professional accounts, as this increases vulnerability in case of a breach.

Finally, prompt reporting of suspicious activities or potential threats is essential. Employees act as the organization's eyes and ears, and their quick action can prevent minor incidents from escalating into major security breaches. This includes reporting unusual emails, unexpected system behavior, or unauthorized access attempts to the IT or security teams immediately. By fulfilling these responsibilities, employees contribute significantly to building a secure organizational environment and minimizing risks.

#### **4. Real-World Examples of Breaches and Lessons Learned**

**Phishing Attack on a Major Company:** An employee at a global financial institution clicked on a phishing email, believing it to be from a trusted client. The attacker gained access to internal systems, causing millions of dollars in losses and exposing sensitive customer data. Proper

training on identifying phishing attempts could have prevented this breach.

**Weak Passwords in a Healthcare Organization:** A staff member reused a weak password across multiple accounts. Attackers gained access to patient records when the password was compromised in a separate breach. Implementing password hygiene practices and MFA would have mitigated this risk.

**Social Engineering in a Tech Company:** A hacker posed as an IT technician and convinced an employee to share their login credentials. The hacker used these to install malware, disrupting operations for days. Employees should always verify the identity of anyone requesting sensitive information.

#### **5. Proactive Behavior Prevents Breaches**

**Training and Awareness:** Regular cybersecurity training helps employees stay informed about evolving threats. Awareness campaigns, such as phishing simulations, reinforce safe practices. Training and awareness are foundational elements of a robust cybersecurity strategy. In an ever-evolving threat landscape, regular cybersecurity training equips employees with the knowledge and skills needed to identify and respond to emerging risks effectively. These training programs provide employees with an understanding of common cyber threats, such as phishing, ransomware, and social engineering, as well as the tools and best practices for mitigating them. By staying informed, employees can act as proactive defenders against potential breaches rather than passive participants.

Awareness campaigns, such as phishing simulations, further reinforce these safe practices by providing hands-on, practical learning experiences. For instance, simulated phishing emails sent to employees can test their ability to detect suspicious messages without the actual risk of harm. These exercises not only highlight areas where additional training might be needed but also build confidence in recognizing and avoiding real threats. Repeated exposure to such scenarios helps employees internalize cybersecurity habits, turning them into routine behaviors

**Empowerment:** Encourage employees to take ownership of their role in cybersecurity. This includes speaking up when they notice unusual activity or feel uncertain about a security-related action.

**Team Accountability:** Foster a culture where cybersecurity is seen as a shared, non-judgmental responsibility. Reporting mistakes early can often prevent major incidents.

### **Key Takeaways**

**Cybersecurity is a team effort:** Every employee contributes to the security of the organization. Individual actions have significant impacts: Practicing vigilance and safe habits can prevent costly breaches.

**Real-world lessons emphasize vigilance:** Learning from past incidents underscores the importance of shared responsibility. A culture of cybersecurity awareness: Proactive and informed employees are the cornerstone of strong organizational security.

By emphasizing these points, employees can better understand their critical role in maintaining a secure and resilient organization.

- Ch A S Murty

In today's complex cyber environment, a single layer of defense is insufficient for mitigating the ever-evolving threat landscape. For Chief Information Security Officers (CISOs), implementing a **Defense in Depth** (DiD) strategy is essential for building a robust, multi-layered security posture that reduces risk across all levels of an organization. This article explores the critical components of Defense in Depth and offers a structured approach for CISOs aiming to build and manage an effective, resilient security program.

### **Understanding Defense in Depth (DiD)**

Defense in Depth is a security concept that deploys multiple layers of controls and safeguards to protect data and resources. It is based on the principle that if one layer fails, other defenses remain to mitigate the threat. DiD works by incorporating protective, detective, and corrective controls at every level, making it increasingly difficult for attackers to succeed.

Core Principles of Defense in Depth

1. **Layered Security:** DiD builds redundancy across layers so that no single point of failure compromises the system. Attackers encounter multiple barriers, making their task complex and time-consuming.
2. **Threat Intelligence and Real-Time Monitoring:** DiD leverages intelligence to predict, detect, and respond to threats. The layered approach uses active monitoring and log analysis to identify anomalies early in the attack chain.
3. **Continuous Improvement:** DiD requires constant updating and testing of security protocols as new threats and technologies emerge. A CISO's role is to ensure the agility of the DiD framework by regularly evaluating its effectiveness.

### Key Components of Defense in Depth

- **Perimeter Security:**
  - **Firewalls and Intrusion Detection Systems (IDS)** are the first line of defense.
  - Regularly update firewall rules and conduct penetration tests to validate perimeter security.
- **Network Segmentation:**
  - Segment networks based on user roles and data sensitivity. **Zero Trust Architecture** principles can help to restrict lateral movement across systems.
  - Implement VPNs and VLANs to secure communications between segments.
- **Endpoint Protection:**
  - Use **Endpoint Detection and Response (EDR)** tools to monitor and protect devices against malware and unauthorized access.
  - Develop robust mobile and endpoint security policies, including BYOD (Bring Your Own Device) guidelines
- **Access Management:**
  - Implement **Multi-Factor Authentication (MFA)** and **Role-Based Access Control (RBAC)** to enforce strict access controls.
  - Regularly audit access privileges and adopt the **principle of least privilege** to reduce potential insider threats.
- **Data Security:**
  - Use **encryption** for sensitive data, both at rest and in transit.
  - Implement **Data Loss Prevention (DLP)** policies to monitor, detect, and prevent unauthorized data transfers.

- **Application Security:**
  - Secure software development practices are vital to prevent vulnerabilities in applications. Consider **Secure Software Development Life Cycle (SDLC)** and regular **application security testing**.
  - Use **Web Application Firewalls (WAF)** to protect applications from common threats such as SQL injection and cross-site scripting
- **Human Element:**
  - Conduct regular **security awareness training** to educate employees on phishing, social engineering, and other common attack vectors.
  - Establish a clear incident response procedure that is well-communicated across the organization.
- **Incident Response and Recovery:**
  - Develop and maintain an **Incident Response (IR) plan** that outlines actions for detecting, responding to, and recovering from security incidents.
  - Regularly perform **drills and tabletop exercises** to assess IR readiness.
- **Backup and Disaster Recovery:**
  - Implement regular backups and maintain a **Disaster Recovery Plan (DRP)** to ensure business continuity.
  - Test data recovery processes to validate that backups are effective and readily available.

## Steps to Implement Defense in Depth for a CISO

**Conduct a Comprehensive Risk Assessment:** Start by understanding the organization's most critical assets, assessing their exposure to risks, and identifying current security gaps.

**Define a Layered Security Architecture:** Develop a structured plan for each security layer based on the specific needs of your organization. Tailor your controls to protect key systems and data.

**Align Security with Business Objectives:** Ensure security measures align with business priorities and regulatory requirements. A successful DiD strategy balances security with operational efficiency.

**Utilize Automation and AI:** Automate routine security tasks like log analysis, patch management, and threat detection to free up resources for high-impact initiatives. AI-driven threat intelligence can improve the accuracy and speed of incident response.

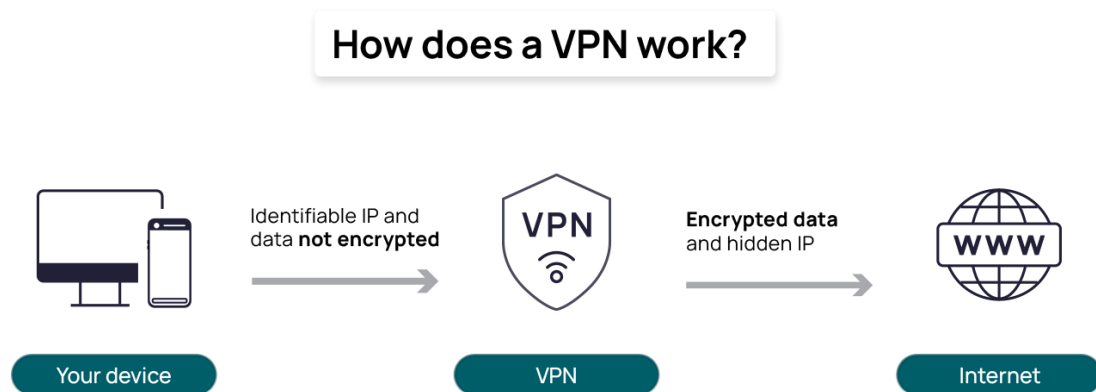
**Monitor and Adjust Continuously:** Cyber threats are always evolving, so your defense mechanisms must evolve, too. Regularly review and update each security layer, and conduct audits to ensure the effectiveness of controls.

**Collaborate and Communicate:** Ensure open communication between IT, security, and business teams to foster a unified security culture. Collaborative effort is essential for the effective implementation of DiD.

For CISOs, Defense in Depth is not a one-time initiative but a continuous journey. By systematically layering defenses across all facets of the organization, you can mitigate risks and enhance resilience against modern cyber threats. While implementing DiD may require substantial resources and planning, the payoff in risk reduction and operational security is well worth the investment.

## Introduction

In the digital age, data privacy and secure internet connections are paramount for individuals and organizations alike. Virtual Private Networks (VPNs) have become popular solutions for ensuring privacy, securing sensitive information, and providing safe access to remote networks. Yet, like any tool, VPNs are not without their risks. Misunderstanding the limitations or security challenges of VPNs can lead to serious vulnerabilities. This article dives deep into the purpose and advantages of VPNs, the inherent risks associated with their use, and the best practices to ensure a secure and effective VPN environment.



## What is a VPN and Why is it Essential?

A Virtual Private Network (VPN) is a service that establishes a secure, encrypted connection between a user's device and the internet, often referred to as a "tunnel." This secure pathway hides the user's IP address and encrypts data transmissions, making it a valuable tool for maintaining privacy and security in an increasingly interconnected world.

## Key Benefits of Using a VPN

### 1. Enhanced Security

VPNs encrypt data transmitted over the internet, making it difficult for unauthorized parties to access or intercept sensitive information. This encryption is especially beneficial when connecting to unsecured public Wi-Fi networks, where malicious actors can easily exploit open network vulnerabilities.

### 2. Improved Privacy

VPNs shield personal data and browsing activities from internet service providers (ISPs), advertisers, and other third parties. This helps users maintain privacy in a world where online tracking has become routine.

### 3. Remote Access for Businesses

VPNs allow employees to access company networks from remote locations, ensuring secure data transmission for an increasingly remote workforce. This can be a critical tool for accessing internal resources and staying connected to the company infrastructure from virtually anywhere.

### 4. Bypassing Geo-Restrictions

Many services and websites restrict content based on geographical location. VPNs allow users to circumvent these restrictions by masking their location, granting access to restricted resources for entertainment or research purposes.

## **Recognizing the Risks of VPN Use**

Despite their many benefits, VPNs introduce certain risks that users should be aware of:

### 1. Security Vulnerabilities

Improperly configured VPNs or outdated software versions can contain vulnerabilities, which hackers may exploit to gain unauthorized access to user data. For example, weak encryption protocols or misconfigured servers can render a VPN connection insecure.

### 2. Trust Issues with VPN Providers

Using a VPN often requires trusting the provider with your data. Some VPN providers log user activities or may sell user data to third parties, compromising privacy. Selecting a reputable VPN provider is essential to prevent such privacy breaches.

### 3. Performance and Latency Issues

VPNs can impact internet speeds, as data encryption and routing through remote servers create additional processing demands. While premium VPNs attempt to mitigate these performance issues, users may still experience lag or slower response times, particularly in bandwidth-intensive applications.

#### 4. Legal and Regulatory Constraints

VPN usage is restricted or outright banned in certain countries. Users should be aware of the legal implications of VPN usage in their respective regions, as violating these laws can lead to fines or other penalties.

### **Best Practices for a Secure and Effective VPN Setup**

Ensuring VPN security is crucial for preventing breaches and maintaining data integrity. Here are best practices to maximize VPN security:

#### 1. Implement Multi-Factor Authentication (MFA)

Enabling MFA requires users to provide multiple forms of verification, such as a password and a code sent to their phone. MFA adds an additional layer of protection, safeguarding access even if the password is compromised.

#### 2. Regularly Update VPN Software

VPN applications, like all software, are subject to ongoing development to patch vulnerabilities. Regularly updating the VPN application ensures protection against the latest threats and software exploits.

#### 3. Choose a Trusted VPN Provider

Opt for VPN providers known for robust security standards, such as no-log policies and strong encryption. Research provider privacy policies and independent security audits to verify the provider's commitment to user security.

#### 4. Monitor VPN Access and Conduct Regular Audits

Regularly reviewing access logs for unusual activity is essential to detecting potential breaches. Conducting periodic security audits ensures that VPN settings and practices align with your organization's security policies.

#### 5. Implement Network Segmentation

Network segmentation involves creating separate network zones to limit access based on user role and device type. This restricts the spread of potential breaches and minimizes damage if a VPN is compromised.

## 6. Educate Users on VPN Security Practices

Users are often the first line of defense in maintaining security. Training employees and users on secure VPN practices ensures they understand how to use VPNs responsibly, recognize insecure connections, and stay alert to potential threats.

## 7. Deploy Endpoint Security Measures

Ensuring that devices accessing the VPN have updated antivirus software, firewalls, and endpoint security measures helps prevent malware infections and other cyber threats.

### **Technical Overview of VPN Protocols and Encryption Standards**

A secure VPN relies on robust protocols and encryption to safeguard data. Here are some of the most commonly used VPN protocols and their security characteristics:

- **OpenVPN:** This widely-used, open-source protocol offers strong security through AES-256 encryption and works across various operating systems, making it highly versatile and secure.
- **IKEv2/IPsec:** Known for its speed and stability, especially on mobile devices, IKEv2/IPsec uses encryption standards like AES-256, ensuring strong protection with rapid reconnection capabilities.
- **WireGuard:** A newer protocol known for simplicity, speed, and secure cryptographic algorithms, WireGuard provides strong security with less computational overhead than traditional protocols.

VPNs typically rely on 128-bit or 256-bit AES encryption, with 256-bit encryption offering a higher level of security suitable for applications where data protection is paramount. However, this can introduce latency, which is a trade-off for heightened security.

### **Legal and Ethical Considerations When Using VPNs**

Using a VPN entails not only technical and security considerations but also ethical and legal factors:

- **Compliance with Local Laws:** Certain countries restrict VPN usage, while others require providers to log user activity. Users should research and comply with local regulations to avoid legal repercussions.
- **Company Policies:** For organizations, using a VPN aligns with cybersecurity policies to protect sensitive business data. Ensuring that VPN usage complies with company guidelines is essential for consistent security practices.

### **Conclusion**

VPNs play an integral role in securing internet access and protecting personal data in today's digital landscape. However, they are not without risks, and understanding these potential vulnerabilities is crucial to maintaining a secure environment. By following best practices—such as using multi-factor authentication, selecting reputable providers, and educating users—individuals and organizations can enjoy the benefits of VPNs while minimizing security threats.

Through proactive management and ongoing security efforts, VPNs can remain a powerful tool for enhancing privacy, protecting sensitive data, and facilitating secure remote work in an ever-connected world.

In today's digital landscape, web applications play a critical role in delivering services and value to users, with businesses across industries increasingly reliant on them for customer engagement, sales, and service provision. However, as the use of web applications grows, so does the risk of cyber threats, making robust web application security practices essential for protecting sensitive data, maintaining user trust, and safeguarding business continuity.

This article explores ten key practices that form the foundation of a strong web application security strategy. Implementing these measures can significantly improve your application's resilience against attacks, keeping user data secure and ensuring a seamless experience.

## 1. Adhere to Secure Coding Practices

Secure coding practices form the foundation of web application security, preventing vulnerabilities that cyber attackers might exploit. Here are core techniques to ensure code security:

- **Input Validation:** Always validate user inputs to block SQL injection, cross-site scripting (XSS), and other common attacks.
- **Parameterized Queries:** Use parameterized queries to prevent SQL injection attacks.
- **Avoid Hardcoding Sensitive Information:** Store passwords, API keys, and credentials in secure environments, not within the source code.
- **Cryptographic Libraries and Functions:** Use reliable cryptographic libraries to encrypt sensitive data.
- **Regular Code Reviews:** Conduct frequent code audits to catch and address security issues early.

## 2. Implement SSL/TLS for Data Encryption

SSL (Secure Socket Layer) and TLS (Transport Layer Security) protocols secure data transmission between users and your application. Installing SSL/TLS certificates ensures that all communication between the client and server remains encrypted and secure, effectively preventing data interception by malicious actors.

### 3. Apply Regular Updates and Patches

Cyber attackers often exploit outdated software and unpatched vulnerabilities. Regularly updating your software—such as web servers, operating systems, databases, and third-party libraries—can prevent attackers from exploiting known weaknesses. Routinely monitor for patches and apply updates promptly.

### 4. Deploy a Web Application Firewall (WAF)

A Web Application Firewall (WAF) acts as a security filter, protecting your application against various threats, such as SQL injection, XSS, and cross-site request forgery (CSRF). By analyzing and filtering HTTP traffic, WAFs block suspicious requests before they can interact with your application, providing an essential layer of defense against cyber threats.

### 5. Use Strong Authentication Mechanisms

Authentication confirms user identity and is crucial for securing access. Simple password authentication can be vulnerable to brute-force attacks. Implementing **Two-Factor Authentication (2FA)** or **Multi-Factor Authentication (MFA)** adds an extra layer of security, requiring users to provide additional identity proof, like a code sent to their phone or a biometric scan.

### 6. Enforce the Principle of Least Privilege

The principle of least privilege restricts user and system permissions to only what's necessary. By limiting access, you minimize the potential damage from a security breach. Grant minimal permissions for users and systems and restrict sensitive data access to authorized personnel only.

### 7. Validate and Sanitize User Inputs

Input validation helps ensure that any data entered by users is safe and expected. This step is critical for preventing attacks like SQL injection, XSS, and command injection. Validate and sanitize all inputs, including data from form fields, URLs, and cookies, and avoid interpreting any user-provided content as executable code.

### 8. Ensure Robust User Session Management

User sessions are often a target for attackers seeking unauthorized access. Implementing effective session management practices can prevent **session hijacking** (stealing session IDs) and **session fixation** (setting a session ID to a known value). Best practices include:

- **Strong Session IDs:** Generate long, complex session IDs to prevent guessing.
- **Session ID Regeneration:** Change session IDs after login or sensitive actions to prevent unauthorized access.
- **Session Expiration:** Set timeouts to automatically end inactive sessions.

- **Monitor User Activity:** Detect and respond to unusual patterns, which could signal a compromised session.

## 9. Implement Comprehensive Error Handling and Logging

Error handling and logging are essential for identifying and diagnosing potential security issues. However, avoid exposing detailed error messages to users, as they may reveal vulnerabilities. Implement logging for all error events and monitor these logs for anomalies that may indicate security threats.

## 10. Secure File Uploads

Allowing file uploads can be risky if not handled correctly. Attackers can exploit insecure upload systems to introduce malicious files that compromise application security. To mitigate this risk:

- **Restrict File Types:** Allow only certain file formats.
- **Limit File Size:** Prevent excessively large files that could consume resources or crash the system.
- **Scan Files for Malware:** Use automated tools to detect potentially harmful files before storing or processing them.

## Final Thoughts: Building a Secure Web Application

Web application security is fundamental to protecting user data, maintaining business reputation, and ensuring application functionality. By implementing these security best practices, you can reduce the likelihood of a data breach or cyber-attack. Remember, security is a continuous process that requires regular monitoring, updating, and refinement. Make security a top priority to provide your users with a safe online experience, and protect your organization from potential losses and reputational damage.

## Cyber Security Framework in Banks

### Introduction

Use of Information Technology by banks and their constituents has grown rapidly and is now an integral part of the operational strategies of banks. The Reserve Bank, had, provided guidelines on Information Security, Electronic Banking, Technology Risk Management and Cyber Frauds (G.Gopalakrishna Committee) vide [Circular DBS.CO.ITC.BC.No.6/31.02.008/2010-11 dated April 29, 2011](#), wherein it was indicated that the measures suggested for implementation cannot be static and banks need to pro-actively create/fine-tune/modify their policies, procedures and technologies based on new developments and emerging concerns.

2. Since then, the use of technology by banks has gained further momentum. On the other hand, the number, frequency and impact of cyber incidents / attacks have increased

manifold in the recent past, more so in the case of financial sector including banks, underlining the urgent need to put in place a robust cyber security/resilience framework at banks and to ensure adequate cyber-security preparedness among banks on a continuous basis. In view of the low barriers to entry, evolving nature, growing scale/velocity, motivation and resourcefulness of cyber-threats to the banking system, it is essential to enhance the resilience of the banking system by improving the current defences in addressing cyber risks. These would include, but not limited to, putting in place an adaptive Incident Response, Management and Recovery framework to deal with adverse incidents/disruptions, if and when they occur.

### **Need for a Board approved Cyber-security Policy**

3. Banks should **immediately** put in place a cyber-security policy elucidating the strategy containing an appropriate approach to combat cyber threats given the level of complexity of business and acceptable levels of risk, duly approved by their Board. A confirmation in this regard may be communicated to Cyber Security and Information Technology Examination (CSITE) Cell of Department of Banking Supervision, Reserve Bank of India, Central Office, World Trade Centre-I, 4th Floor, Cuffe Parade, Mumbai 400005 at the earliest, and in any case not later than September 30, 2016.

It may be ensured that the strategy deals with the following broad aspects:

### **Cyber Security Policy to be distinct from the broader IT policy / IS Security Policy of a bank**

4. In order to address the need for the entire bank to contribute to a cyber-safe environment, the Cyber Security Policy should be distinct and separate from the broader IT policy / IS Security policy so that it can highlight the risks from cyber threats and the measures to address / mitigate these risks.

5. The size, systems, technological complexity, digital products, stakeholders and threat perception vary from bank to bank and hence it is important to identify the inherent risks and the controls in place to adopt appropriate cyber-security framework. While identifying and assessing the inherent risks, banks are required to reckon the technologies adopted, alignment with business and regulatory requirements, connections established, delivery channels, online / mobile products, technology services, organisational culture and internal & external threats. Depending on the level of inherent risks, the banks are required to identify their riskiness as low, moderate, high and very high or adopt any other similar categorisation. Riskiness of the business component also may be factored into while assessing the inherent risks. While evaluating the controls, Board oversight, policies, processes, cyber risk management architecture including experienced and qualified resources, training and culture, threat intelligence gathering arrangements, monitoring and analysing the threat intelligence received vis-à-vis the situation obtaining in banks, information sharing arrangements (among peer banks, with IDRB/RBI/CERT-In), preventive,

detective and corrective cyber security controls, vendor management and incident management & response are to be outlined.

### **Arrangement for continuous surveillance**

6. Testing for vulnerabilities at reasonable intervals of time is very important. The nature of cyber-attacks are such that they can occur at any time and in a manner that may not have been anticipated. Hence, it is mandated that a SOC (Security Operations Centre) be set up at the earliest, if not yet been done. It is also essential that this Centre ensures continuous surveillance and keeps itself regularly updated on the latest nature of emerging cyber threats.

### **IT architecture should be conducive to security**

7. The IT architecture should be designed in such a manner that it takes care of facilitating the security measures to be in place at all times. The same needs to be reviewed by the IT Sub Committee of the Board and upgraded, if required, as per their risk assessment in a phased manner. The risk cost/potential cost trade off decisions which a bank may take should be recorded in writing to enable an appropriate supervisory assessment subsequently.

8. An indicative, but not exhaustive, minimum baseline cyber security and resilience framework to be implemented by the banks is given in [Annex 1](#). Banks should proactively initiate the process of setting up of and operationalising a Security Operations Centre (SOC) to monitor and manage cyber risks in real time. An indicative configuration of the SOC is given in [Annex 2](#).

### **Comprehensively address network and database security**

9. Recent incidents have highlighted the need to thoroughly review network security in every bank. In addition, it has been observed that many times connections to networks/databases are allowed for a specified period of time to facilitate some business or operational requirement. However, the same do not get closed due to oversight making the network/database vulnerable to cyber-attacks. It is essential that unauthorized access to networks and databases is not allowed and wherever permitted, these are through well-defined processes which are invariably followed. Responsibility over such networks and databases should be clearly elucidated and should invariably rest with the officials of the bank.

### **Ensuring Protection of customer information**

10. Banks depend on technology very heavily not only in their smooth functioning but also in providing cutting-edge digital products to their consumers and in the process collect various personal and sensitive information. Banks, as owners of such data, should take appropriate steps in preserving the Confidentiality, Integrity and Availability of the same, **irrespective** of whether the data is stored/in transit within themselves or with customers or with the third

party vendors; the confidentiality of such custodial information should not be compromised at any situation and to this end, suitable systems and processes across the data/information lifecycle need to be put in place by banks.

### **Cyber Crisis Management Plan**

11. A Cyber Crisis Management Plan (CCMP) should be immediately evolved and should be a part of the overall Board approved strategy. Considering the fact that cyber-risk is different from many other risks, the traditional BCP/DR arrangements may not be adequate and hence needs to be revisited keeping in view the nuances of the cyber-risk. As you may be aware, in India, CERT-IN (Computer Emergency Response Team – India, a Government entity) has been taking important initiatives in strengthening cyber-security by providing proactive & reactive services as well as guidelines, threat intelligence and assessment of preparedness of various agencies across the sectors, including the financial sector. CERT-IN also have come out with National Cyber Crisis Management Plan and Cyber Security Assessment Framework. CERT-In/NCIIPC/RBI/IDRBT guidance may be referred to while formulating the CCMP.

12. CCMP should address the following four aspects: (i) Detection (ii) Response (iii) Recovery and (iv) Containment. Banks need to take effective measures to prevent cyber-attacks and to promptly detect any cyber-intrusions so as to respond / recover / contain the fall out. Banks are expected to be well prepared to face emerging cyber-threats such as ‘zero-day’ attacks, remote access threats, and targeted attacks. Among other things, banks should take necessary preventive and corrective measures in addressing various types of cyber threats including, but not limited to, denial of service, distributed denial of services (DDoS), ransomware / crypto ware, destructive malware, business email frauds including spam, email phishing, spear phishing, whaling, vishing frauds, drive-by downloads, browser gateway fraud, ghost administrator exploits, identity frauds, memory update frauds, password related frauds, etc.

### **Cyber security preparedness indicators**

13. The adequacy of and adherence to cyber resilience framework should be assessed and measured through development of indicators to assess the level of risk/preparedness. These indicators should be used for comprehensive testing through independent compliance checks and audits carried out by qualified and competent professionals. The awareness among the stakeholders including employees may also form a part of this assessment.

### **Sharing of information on cyber-security incidents with RBI**

14. It is observed that banks are hesitant to share cyber-incidents faced by them. However, the experience gained globally indicates that collaboration among entities in sharing the cyber-incidents and the best practices would facilitate timely measures in containing cyber-risks. It is reiterated that banks need to report all unusual cyber-security incidents (whether they were successful or were attempts which did not fructify) to the Reserve Bank. Banks are

also encouraged to actively participate in the activities of their CISOs' Forum coordinated by IDBRT and promptly report the incidents to Indian Banks – Center for Analysis of Risks and Threats (IB-CART) set up by IDBRT. Such collaborative efforts will help the banks in obtaining collective threat intelligence, timely alerts and adopting proactive cyber security measures.

### **Supervisory Reporting framework**

15. It has been decided to collect both summary level information as well as details on information security incidents including cyber-incidents. Banks are required to report promptly the incidents, in the format given in [Annex-3](#).

### **An immediate assessment of gaps in preparedness to be reported to RBI**

16. The material gaps in controls may be identified early and appropriate remedial action under the active guidance and oversight of the IT Sub Committee of the Board as well as by the Board may be initiated immediately. The identified gaps, proposed measures/controls and their expected effectiveness, milestones with timelines for implementing the proposed controls/measures and measurement criteria for assessing their effectiveness including the risk assessment and risk management methodology followed by the bank/proposed by the bank, as per their self-assessment, may be submitted to the Cyber Security and Information Technology Examination (CSITE) Cell of Department of Banking Supervision, Central Office not later than July 31, 2016 by the Chief Information Security Officer.

### **Organisational arrangements**

17. Banks should review the organisational arrangements so that the security concerns are appreciated, receive adequate attention and get escalated to appropriate levels in the hierarchy to enable quick action.

### **Cyber-security awareness among stakeholders / Top Management / Board**

18. It should be realized that managing cyber risk requires the commitment of the entire organization to create a cyber-safe environment. This will require a high level of awareness among staff at all levels. Top Management and Board should also have a fair degree of awareness of the fine nuances of the threats and appropriate familiarisation may be organized. Banks should proactively promote, among their customers, vendors, service providers and other relevant stakeholders an understanding of the bank's cyber resilience objectives, and require and ensure appropriate action to support their synchronised implementation and testing. It is well recognised that stakeholders' (including customers, employees, partners and vendors) awareness about the potential impact of cyber-attacks helps in cyber-security preparedness of banks. Banks are required to take suitable steps in building this awareness. Concurrently, there is an urgent need to bring the Board of Directors and Top Management in banks up to speed on cyber-security related aspects, where necessary, and hence banks are advised to take immediate steps in this direction.

A copy of this circular may be placed before the Board of Directors in its ensuing meeting.

